IT & INFORMATION SECURITY POLICIES

Enterprise Data Protection, Encryption & Classification Policy

Classification Matrix, Cryptographic Standards, Retention, and Media Disposal

Classification: Confidential **Version:** 3.2 **Owner:** Data Governance & Privacy **Standard:** GDPR / ISO 27001

1. Objective and Compliance Baseline

The Enterprise Data Protection Policy establishes standards for data classification, cryptographic protection, retention, and secure disposal across Apex Global Technologies. This policy ensures strict compliance with the **EU General Data Protection Regulation (GDPR)**, **California Consumer Privacy Act (CCPA)**, and **SOC 2 Type II** confidentiality requirements.

2. Data Classification Taxonomy

Classification	Definition & Examples	Handling & Access Constraints
Level 1: Public	Marketing collateral, published blog posts, open-source documentation.	No restrictions; public dissemination approved.
Level 2: Internal	Internal wikis, engineering standards, org charts, all-hands decks.	Restricted to authenticated Apex employees and active contractors.
Level 3: Confidential	Financial forecasts, commercial contracts, source code repositories, system architectures.	Role-based access; requires explicit departmental approval; encrypted in transit and rest.
Level 4: Restricted / PII	Customer personally identifiable information (PII), employee health/payroll records, encryption keys, raw database dumps.	Strict least-privilege; mandatory field-level encryption; access logging; export strictly prohibited without CISO approval.

3. Cryptographic Standards (Encryption at Rest and in Transit)

- **Encryption at Rest:** All databases (PostgreSQL, Redis), Amazon EBS volumes, S3 buckets, and backup archives must be encrypted using **AES-256**. Endpoint laptops must enforce full-disk encryption (Apple FileVault 2 on macOS, BitLocker with TPM 2.0 on Windows).
- **Encryption in Transit:** All data transmitted over internal or external networks must use **TLS 1.3** (with TLS 1.2 permitted as a legacy fallback). Cleartext protocols (HTTP, Telnet, FTP) are blocked at the perimeter firewall.

4. Data Retention, Archival, and Sanitization

- **Retention Schedules:** Operational application logs are retained for 90 days in hot storage and archived for 365 days in cold storage (AWS S3 Glacier). Customer datasets are deleted within 30 days of contract termination.
- **Media Sanitization:** Decommissioned hardware storage devices must undergo cryptographic erasure complying with **NIST SP 800-88 Revision 1 (Guidelines for Media Sanitization)** or physical degaussing and shredding with a Certificate of Destruction.